Rapport TP 4.1 – MISE EN PLACE D’UN PARE-FEU pfSense ET SEGMENTATION DU LABORATOIRE

OBJECTIF

L'objectif principal de ce travail pratique est de transformer une architecture réseau initialement ouverte en une infrastructure sécurisée et segmentée. En introduisant pfSense comme pare-feu central, nous visons à :

- Contrôler les flux réseau entre les différentes zones (LAN et WAN).
- Limiter la surface d'attaque du laboratoire.

Passer d'une posture offensive à une posture de défense active (administrateur sécurité/analyste SOC).

Configurations et captures d’écran

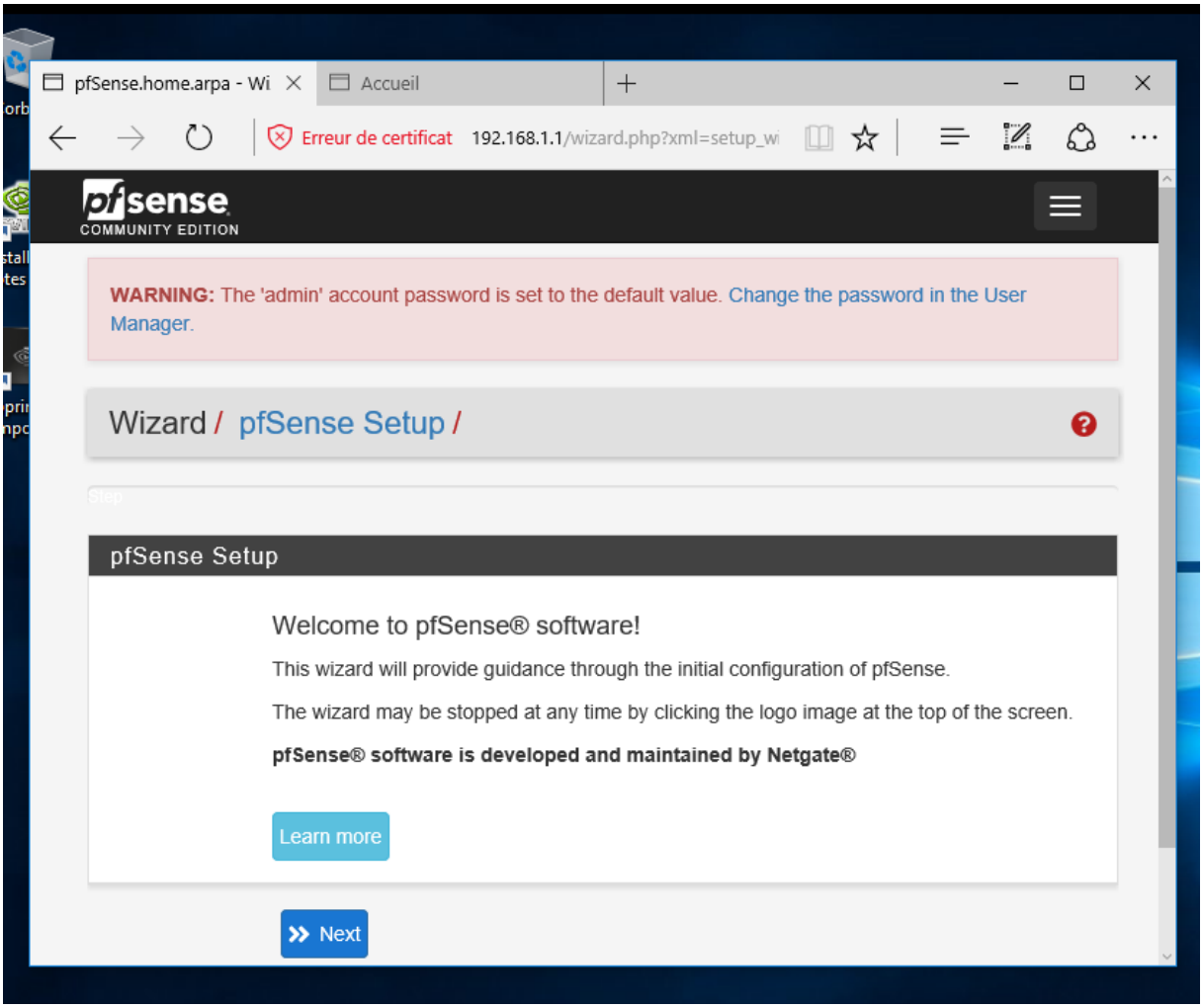
- **Configuration réseaux des VMs**

Les machines Ubuntu et Windows ont été configurées pour utiliser pfSense comme passerelle

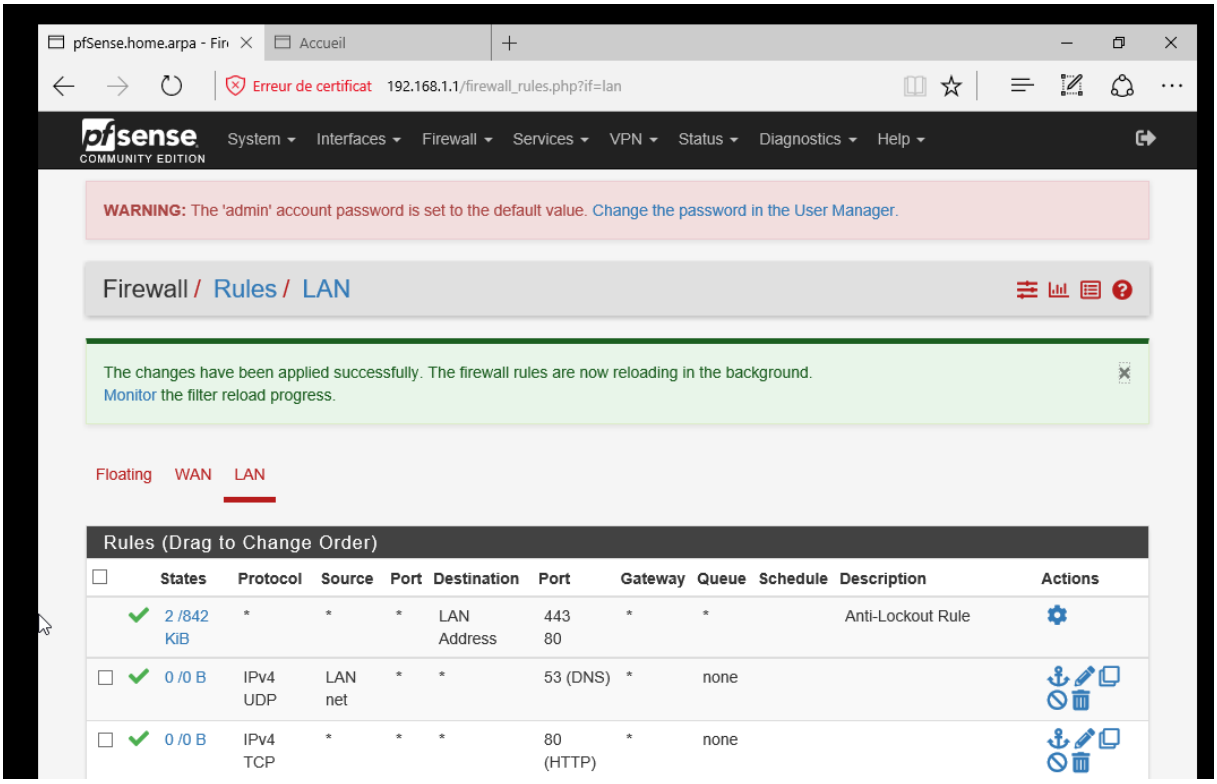
```
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens38: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 00:0c:29:b8:1d:0e brd ff:ff:ff:ff:ff:ff
    altname enp2s6
    inet 192.168.1.10/24 scope global ens38
       valid_lft forever preferred_lft forever
ntoguem@juniorntoguem:~$ sudo ip route add default via 192.168.1.1
Error: Nexthop has invalid gateway.
ntoguem@juniorntoguem:~$ sudo ip link set ens38 up
ntoguem@juniorntoguem:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens38: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:b8:1d:0e brd ff:ff:ff:ff:ff:ff
    altname enp2s6
    inet 192.168.1.10/24 scope global ens38
       valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:feb8:1d0e/64 scope link
       valid_lft forever preferred_lft forever
ntoguem@juniorntoguem:~$ sudo ip route add default via 192.168.1.1 dev ens38
ntoguem@juniorntoguem:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens38: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:b8:1d:0e brd ff:ff:ff:ff:ff:ff
    altname enp2s6
    inet 192.168.1.10/24 scope global ens38
       valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:feb8:1d0e/64 scope link
       valid_lft forever preferred_lft forever
ntoguem@juniorntoguem:~$ ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
64 bytes from 192.168.1.1: icmp_seq=1 ttl=64 time=2.44 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=64 time=3.51 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=64 time=2.71 ms
64 bytes from 192.168.1.1: icmp_seq=4 ttl=64 time=3.15 ms
^C
--- 192.168.1.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3013ms
rtt min/avg/max/mdev = 2.440/2.950/3.511/0.410 ms
ntoguem@juniorntoguem:~$ _
```

- **Interface pfSense**

L'administration se fait via l'interface web (HTTPS://192.168.1.1) avec les identifiants par défaut (admin /pfSense).



- **Règles de filtrage créées**



Résultat des Tests Fonctionnement

Apres application de la configuration, les tests suivants ont été effectué depuis la machine Ubuntu :

Test http (curl http://example.com**) :** SUCCES. La communication sur le port 80 est autorisée par la règles explicite.

```
ntoguem@juniorntoguem:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3075ms

ntoguem@juniorntoguem:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3093ms

ntoguem@juniorntoguem:~$ curl http://example.com
<!doctype html><html lang="en"><head><title>Example Domain</title><meta name="viewport" content="width=device-width, initial-scale=1"><style>body{background:#ee
e;width:60vw;margin:15vh auto;font-family:system-ui,sans-serif}h1{font-size:1.5em}div{opacity:0.8}a:link,a:visited{color:#348}</style></head><body><div><h1>Exam
ple Domain</h1><p>This domain is for use in documentation examples without needing permission. Avoid use in operations.</p><p><a href="https://iana.org/domains/
example">Learn more</a></p></div></body></html>
ntoguem@juniorntoguem:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
^C
--- 8.8.8.8 ping statistics ---
114 packets transmitted, 0 received, 100% packet loss, time 115736ms

ntoguem@juniorntoguem:~$
```

- **Test de connectivité ICMP (ping 8.8.8.8) :** ÉCHEC. Aucune règle n'autorisant le protocole ICMP, le trafic est bloqué par défaut.

- **Test de Scan (nmap -sS 8.8.8.8) :** ÉCHEC. pfSense bloque les tentatives de scan sortant, empêchant la reconnaissance réseau.

```
No VM guests are running outdated hypervisor (qemu) binaries on this host.
ntoguem@juniorntoguem:~$ nmap -sS 8.8.8.8
You requested a scan type which requires root privileges.
QUITTING!
ntoguem@juniorntoguem:~$ _
```

Analyse de la Règles

- **Pourquoi la règle fonctionne ?** pfSense applique une politique de "Deny All" par défaut. Seul ce qui est explicitement autorisé passe. Comme nous avons créé une règle "Pass" spécifiant le protocole TCP et le port 80, pfSense inspecte chaque paquet sortant du LAN et ne laisse passer que ceux correspondant à ces critères.
- **Ce qu'elle bloque :**

Elle bloque tous les autres ports (DNS/53, HTTPS/443, SSH/22, etc.) ainsi que les autres protocoles comme ICMP (ping) ou UDP. Cela empêche une machine compromise d'exfiltrer des données via des tunnels non conventionnels ou de scanner le réseau externe.

- **Ce qu'elle autorise :**

Exclusivement le trafic web sortant sur le port 80.

Proposition d’Amélioration

- **Transition vers HTTPS uniquement :** Modifier la règle pour autoriser le port 443 (TCP) et bloquer le port 80 afin de garantir le chiffrement des communications.
- **Filtrage granulaire :** Bloquer des ports spécifiques souvent utilisés par les malwares pour le Command & Control (C2), comme le port 6667 (IRC) ou des ports de base de données.
- **Mise en place d'une DMZ :** Créer une troisième zone isolée pour les serveurs devant être accessibles depuis l’extérieure, évitant qu’une compromission de ces serveurs ne donne un accès direct au LAN.

Conclusion

Ce TP démontre que la sécurité commence par la maîtrise du réseau. La segmentation et le contrôle des flux via pfSense permettent de limiter drastiquement les capacités d'un attaquant, même si celui-ci parvient à prendre le contrôle d'un poste de travail.